

Physical Schema Design – Authentication, MFA & Recovery

Target RDBMS: PostgreSQL 15 (adjust types for other engines as needed) **Naming convention:** snake_case table & column names; singular table names for core entities, plural for log/event tables. **All timestamp columns** use `TIMESTAMPTZ` (UTC) and default to `NOW()`. All surrogate PKs are `BIGINT GENERATED ALWAYS AS IDENTITY`.

1. Core Entity Tables

Table	Purpose	Key Columns
user_account	Master record for every login-capable person. Distinguishes Issuer vs Fan and stores immutable identifiers.	<code>user_id</code> PK, <code>username</code> UNIQUE NOT NULL CHECK (length(username) BETWEEN 4 AND 20), <code>user_type</code> SMALLINT NOT NULL CHECK (user_type IN (1,2)) — 1=Issuer,2=Fan, <code>status</code> SMALLINT, <code>created_at</code> , <code>updated_at</code>
issuer_profile	Issuer-specific data (social follower metadata, verification status, etc.).	<code>user_id</code> PK/FK → user_account, <code>primary_platform</code> VARCHAR(32), <code>secondary_platform</code> VARCHAR(32), <code>primary_handle</code> VARCHAR(64), <code>secondary_handle</code> VARCHAR(64), <code>primary_followers</code> INT, <code>secondary_followers</code> INT, <code>verified_at</code>
fan_profile	Fan-specific demographic or preference columns (add as needed).	<code>user_id</code> PK/FK → user_account, ...

2. Credential & Authentication Data

Table	Purpose	Selected Columns
login_credential	One row per <i>local</i> credential (email + password) or passkey.	credential_id PK, user_id FK, credential_type SMALLINT CHECK (credential_type IN (1,2)) — 1 = email_password, 2 = passkey, email CTEXT UNIQUE, password_hash BYTEA, passkey_public_key BYTEA, created_at, revoked_at
social_account	OAuth / social-login bindings. Multiple per user possible.	social_id PK, user_id FK, provider VARCHAR(24), provider_user_id VARCHAR(128), linked_on, last_login
mfa_secret	TOTP secret for users with MFA enabled.	user_id PK/FK, secret_encrypted BYTEA NOT NULL, enabled BOOLEAN NOT NULL, issuer_label VARCHAR(32) DEFAULT 'ATHL', algorithm VARCHAR(8) DEFAULT 'SHA1', digits SMALLINT DEFAULT 6, period SMALLINT DEFAULT 30, created_at, last_rotated_at
mfa_backup_code	10-12 single-use codes per batch.	code_id PK, user_id FK, batch_id UUID NOT NULL, code_hash BYTEA NOT NULL, used BOOLEAN DEFAULT FALSE, used_at
security_question	Canonical list of allowed questions.	question_id PK, question_text VARCHAR(160) UNIQUE
user_security_answer	User-specific hashed answers.	user_id FK, question_id FK, answer_hash BYTEA, created_at, PRIMARY KEY (user_id, question_id)

3. Session & Rate-Limiting Tables

Table	Purpose	Columns
login_session	Active JWT / session tokens.	session_id UUID PK, user_id FK, ip INET, user_agent TEXT, issued_at, expires_at, last_activity_at, is_revoked BOOLEAN

Table	Purpose	Columns
auth_attempt	Every username/password/social/MFA attempt (success or failure). Used for lockouts & auditing. Partition by month on <code>attempt_at</code> .	<code>attempt_id</code> PK, <code>user_id</code> NULLABLE, <code>username_entered</code> VARCHAR(20), <code>phase</code> SMALLINT — 1=primary_login, 2=mfa, 3=backup_code, <code>success</code> BOOLEAN, <code>failure_reason</code> VARCHAR(32), <code>ip</code> INET, <code>user_agent</code> TEXT, <code>attempt_at</code>
account_lockout	Current lockout window state to avoid hot aggregation.	<code>user_id</code> PK, <code>lockout_until</code> TIMESTAMPTZ, <code>failure_count</code> SMALLINT, <code>updated_at</code>

4. Recovery & Support

Table	Purpose	Columns
mfa_recovery_request	Tracks loss-of-device flows.	<code>request_id</code> PK, <code>user_id</code> FK, <code>email_link_sent_at</code> , <code>email_verified_at</code> , <code>questions_passed</code> BOOLEAN, <code>status</code> SMALLINT — 0=pending, 1=completed, 2=failed, <code>completed_at</code>
support_ticket_link	Optionally map recovery to a support system.	<code>ticket_id</code> VARCHAR(32) PK, <code>request_id</code> FK, <code>created_at</code>

5. Event & Audit Logs

Table	Purpose	Notes
mfa_event	Immutable record of MFA lifecycle events (setup, verification, lockout, recovery). Partition monthly .	Columns: <code>event_id</code> PK, <code>user_id</code> FK, <code>event_type</code> VARCHAR(24), <code>event_meta</code> JSONB, <code>ip</code> INET, <code>event_at</code>
login_activity_view	<i>Materialized view</i> summarising last-N logins per user for the issuer dashboard. Refresh every 15 min.	

6. Constraints & Indexing Highlights

- Unique constraints:** `user_account.username`, `login_credential.email`, `social_account(provider, provider_user_id)`.
- FK cascading:** Use `ON DELETE CASCADE` from child → `user_account` to auto-clean on GDPR deletion.

3. **Lockout logic:** Application queries `account_lockout`; DB checks and updates within a transaction for atomicity.
4. **Hashing & encryption:** `password_hash`, `code_hash`, and `answer_hash` use Argon2id; `secret_encrypted` is AES-GCM wrapped with KMS.
5. **Partitioning:** `auth_attempt`, `mfa_event` range partitioned by month; older partitions may be moved to cheaper storage.
6. **Recommended indexes:**

```
CREATE INDEX idx_auth_attempt_user_time ON auth_attempt (user_id,
attempt_at DESC);
CREATE INDEX idx_mfa_backup_code_user_batch ON mfa_backup_code (user_id,
batch_id) WHERE used = false;
CREATE INDEX idx_login_session_user_active ON login_session (user_id)
WHERE is_revoked = false;
```

7. Security & Compliance Notes

Control	Implementation
TLS/HTTPS	Enforced at load balancer; db connections use TLS 1.3.
PII encryption	Email, TOTP secret, backup codes, security answers encrypted at rest.
Audit retention	Keep <code>auth_attempt</code> & <code>mfa_event</code> 2 years rolling; expire partitions after export to cold storage.
RBAC	Split reader/writer roles; SOC2 policies enforced.

8. Mapping to Flowchart & Requirements

Flow Segment	Primary Tables Used
<i>Username Entry</i>	<code>user_account</code> , <code>auth_attempt</code>
<i>Social vs Email/Passkey</i>	<code>social_account</code> , <code>login_credential</code>
<i>TOTP Prompt & Verification</i>	<code>mfa_secret</code> , <code>auth_attempt</code> , <code>account_lockout</code>
<i>Backup Codes</i>	<code>mfa_backup_code</code>
<i>Recovery</i>	<code>mfa_recovery_request</code> , <code>user_security_answer</code> , <code>security_question</code>
<i>Lockouts & Rate-Limit</i>	<code>account_lockout</code> , <code>auth_attempt</code>

Next Steps

1. **Integrate Existing Tables** – Compare your Excel-defined tables to the structures above; rename or merge where overlapping.
2. **Generate ERD** – Tools like dbdiagram.io or Mermaid can convert these definitions; FK arrows follow the PK/FK notes.
3. **Apply Migration** – Create `V1__init.sql` for Flyway / Liquibase containing these DDL statements.
4. **Iterate** – Provide the Excel to align naming, or let me know additional attributes (e.g., marketing consents) to extend the schema.

Prepared June 8 2025 – ChatGPT (o3)

9. Analytics-Friendly Warehouse Star Schema

Warehouse Engine Assumed: Snowflake / BigQuery / Redshift RA3 (column-oriented) **Time Zone:** All timestamps stored in UTC; local conversions handled in BI layer.

9.1 Conformed Dimension Tables (Full Column Lists)

Dimension	Column	Type	Notes
dim_user	user_sk	BIGINT PK	Surrogate key (SCD-2)
	user_id	BIGINT NK	Source system ID
	username	VARCHAR(20)	Current username
	user_type	VARCHAR(10)	'issuer' / 'fan'
	mfa_enabled_flag	BOOLEAN	True if MFA enabled
	signup_date_sk	INT	Date surrogate for signup date
	first_login_ts	TIMESTAMPTZ	First successful login
	last_login_ts	TIMESTAMPTZ	Most recent login
	is_current	BOOLEAN	SCD2 current-row flag
	effective_from	TIMESTAMPTZ	SCD2 start
	effective_to	TIMESTAMPTZ	SCD2 end (9999-12-31 for current)
dim_date	date_sk	INT PK YYYYMMDD	
	date	DATE	
	year	INT	Calendar year

Dimension	Column	Type	Notes
	quarter	INT	1-4
	month	INT	1-12
	month_name	VARCHAR(9)	
	day_of_month	INT	1-31
	day_of_week_num	INT	1-7 (Mon=1)
	day_of_week_name	VARCHAR(9)	
	is_weekend	BOOLEAN	
dim_time	time_sk	INT PK HHMM	4-digit integer (e.g., 1329)
	hour	INT	0-23
	minute	INT	0-59
	time_bucket_15m	VARCHAR(5)	e.g., '13:15'
dim_device	device_sk	BIGINT PK	
	user_agent	VARCHAR(256)	Raw UA string
	device_type	VARCHAR(12)	desktop / mobile / tablet
	browser_family	VARCHAR(32)	Chrome, Safari...
	browser_version	VARCHAR(16)	Major.minor
	os_family	VARCHAR(32)	Windows, MacOS, iOS...
	os_version	VARCHAR(16)	
dim_social_provider	social_provider_sk	BIGINT PK	
	provider_name	VARCHAR(20)	Twitter, Google, Facebook, Instagram
	provider_category	VARCHAR(12)	social / enterprise
dim_login_method	login_method_sk	BIGINT PK	
	method	VARCHAR(16)	email_password / social / passkey
	social_provider_sk	BIGINT FK	— nullable
	description	VARCHAR(64)	
dim_mfa_method	mfa_method_sk	BIGINT PK	
	mfa_method	VARCHAR(12)	TOTP / backup_code

Dimension	Column	Type	Notes
dim_outcome	description	VARCHAR(64)	
	outcome_sk	BIGINT PK	
	outcome_name	VARCHAR(12)	success / failure / lockout
	outcome_category	VARCHAR(12)	auth / mfa
	is_success_flag	BOOLEAN	
dim_location	location_sk	BIGINT PK	
	ip	VARCHAR(45)	IPV4/6 string
	country_code	CHAR(2)	ISO-3166
	region	VARCHAR(64)	State / province
	city	VARCHAR(64)	
	latitude	DECIMAL(9,6)	Optional
	longitude	DECIMAL(9,6)	Optional
	is_vpn_proxy	BOOLEAN	Flag from IP intelligence

9.2 Fact Tables (Detailed Columns)

All facts are **insert-only** (no updates) unless correcting late-arriving data via MERGE. Partition on `date_sk`; cluster on `user_sk`.

Column	fact_login_attempt	fact_mfa_event	fact_session	Type
surrogate_pk	— (optional)	—	—	Surrogate key, not required for uniqueness if available
date_sk	✓	✓	✓	INT
time_sk	✓	✓	✓ (session start)	INT
user_sk	✓	✓	✓	BIGINT
device_sk	✓	✓	✓	BIGINT
login_method_sk	✓	—	✓	BIGINT
mfa_method_sk	—	✓	(nullable)	BIGINT

Column	fact_login_attempt	fact_mfa_event	fact_session	Type
location_sk	✓	✓	✓	BIGINT
outcome_sk	✓	✓	—	BIGINT
Business IDs	attempt_id BIGINT	mfa_event_id BIGINT	session_id BIGINT/UUID	Helpful drill-t
Metrics	attempt_cnt (1) success_flag failure_flag lockout_level attempt_number_in_window	mfa_attempt_cnt (1) mfa_success_flag mfa_failure_flag lockout_stage	session_cnt (1) session_duration_sec pageviews_est was_mfa_required_flag	
Load metadata	etl_loaded_at TIMESTAMPTZ	Same	Same	For lin debug

9.3 Source→Warehouse Mapping Snapshot

Source (Excel)	Dimension / Fact	Transform Highlights
user_login	fact_login_attempt	Parse UA → dim_device; derive login_method via credential columns; geo-enrich IP to dim_location; success → dim_outcome.
mfa_log	fact_mfa_event	Map event_type to dim_mfa_method; join dim_outcome.
login_session	fact_session	Compute duration; infer was_mfa_required_flag via lookup.
user_account, user_mfa	dim_user	SCD2 merge on business key user_id.
ip_geo lookup	dim_location	Maintain slowly-changing proxy/VPN flags.

9.4 dbt Model Layer Overview

- **stg_***: raw CDC / CSV tables from Excel ingested via Fivetran or custom Airflow.
- **int_***: cleaned joins to attach device & location dims.
- **dim_***: SCD2/Type2 & t-dimension builds.
- **fact_***: incremental insert models with `{{ dbt_utils.surrogate_key(...) }}` for deterministic hashing when required.
- Unit tests: use `dbt_expectations.expect_table_row_count_to_be_between` for sanity on daily loads.

9.5 Example KPI Queries

1. Login Success Rate (Last 30 Days):


```
SELECT d.date,
       SUM(f.success_flag)::decimal / SUM(f.attempt_cnt) AS
login_success_rate
FROM fact_login_attempt f
JOIN dim_date d USING (date_sk)
WHERE d.date >= CURRENT_DATE - 30
GROUP BY d.date;
```

2. MFA Prompt Conversion by Method:

```
SELECT m.mfa_method,
       SUM(f.mfa_success_flag)::decimal / SUM(f.mfa_attempt_cnt) AS
totp_success_rate
FROM fact_mfa_event f
JOIN dim_mfa_method m USING (mfa_method_sk)
GROUP BY m.mfa_method;
```

3. Avg Session Duration by Device Type (Issuers):

```
SELECT dv.device_type,
       AVG(f.session_duration_sec) AS avg_session_sec
FROM fact_session f
JOIN dim_device dv USING (device_sk)
JOIN dim_user u USING (user_sk)
WHERE u.user_type = 'issuer'
GROUP BY dv.device_type;
```

9.6 Governance Checklist

Aspect	Control
Data Quality	dbt tests on NOT NULL FKs, <code>dim_user.is_current</code> uniqueness
Privacy	Mask <code>ip</code> & <code>username</code> outside secure schemas; restrict <code>dim_user</code> PII to analyst role
Audit	Insert ETL row counts into <code>etl_audit_log</code> fact

9.7 Mermaid ER Diagram – Star Schema (Restored)

Paste this snippet into the [Mermaid Live Editor](#) (or any Markdown preview that supports Mermaid) to visualize the facts and dimensions:

```
erDiagram
    DIM_USER {
        BIGINT user_sk PK
```

```

        BIGINT user_id NK
    }
    DIM_DATE {
        INT date_sk PK
    }
    DIM_TIME {
        INT time_sk PK
    }
    DIM_DEVICE {
        BIGINT device_sk PK
    }
    DIM_LOGIN_METHOD {
        BIGINT login_method_sk PK
    }
    DIM_MFA_METHOD {
        BIGINT mfa_method_sk PK
    }
    DIM_OUTCOME {
        BIGINT outcome_sk PK
    }
    DIM_LOCATION {
        BIGINT location_sk PK
    }
    FACT_LOGIN_ATTEMPT {
        INT date_sk FK
        INT time_sk FK
        BIGINT user_sk FK
        BIGINT device_sk FK
        BIGINT login_method_sk FK
        BIGINT location_sk FK
        BIGINT outcome_sk FK
        INT attempt_cnt
        INT success_flag
        INT failure_flag
    }
    FACT_MFA_EVENT {
        INT date_sk FK
        INT time_sk FK
        BIGINT user_sk FK
        BIGINT device_sk FK
        BIGINT mfa_method_sk FK
        BIGINT location_sk FK
        BIGINT outcome_sk FK
        INT mfa_attempt_cnt
        INT mfa_success_flag
        INT mfa_failure_flag
    }

```

```

}

FACT_SESSION {
    INT date_sk FK
    INT time_sk FK
    BIGINT user_sk FK
    BIGINT device_sk FK
    BIGINT login_method_sk FK
    BIGINT mfa_method_sk FK
    BIGINT location_sk FK
    INT session_cnt
    INT session_duration_sec
    INT was_mfa_required_flag
}

%% Relationships - dimensions to FACT_LOGIN_ATTEMPT
DIM_USER ||--o{ FACT_LOGIN_ATTEMPT : user_sk
DIM_DATE ||--o{ FACT_LOGIN_ATTEMPT : date_sk
DIM_TIME ||--o{ FACT_LOGIN_ATTEMPT : time_sk
DIM_DEVICE ||--o{ FACT_LOGIN_ATTEMPT : device_sk
DIM_LOGIN_METHOD ||--o{ FACT_LOGIN_ATTEMPT : login_method_sk
DIM_LOCATION ||--o{ FACT_LOGIN_ATTEMPT : location_sk
DIM_OUTCOME ||--o{ FACT_LOGIN_ATTEMPT : outcome_sk

%% FACT_MFA_EVENT
DIM_USER ||--o{ FACT_MFA_EVENT : user_sk
DIM_DATE ||--o{ FACT_MFA_EVENT : date_sk
DIM_TIME ||--o{ FACT_MFA_EVENT : time_sk
DIM_DEVICE ||--o{ FACT_MFA_EVENT : device_sk
DIM_MFA_METHOD ||--o{ FACT_MFA_EVENT : mfa_method_sk
DIM_LOCATION ||--o{ FACT_MFA_EVENT : location_sk
DIM_OUTCOME ||--o{ FACT_MFA_EVENT : outcome_sk

%% FACT_SESSION
DIM_USER ||--o{ FACT_SESSION : user_sk
DIM_DATE ||--o{ FACT_SESSION : date_sk
DIM_TIME ||--o{ FACT_SESSION : time_sk
DIM_DEVICE ||--o{ FACT_SESSION : device_sk
DIM_LOGIN_METHOD ||--o{ FACT_SESSION : login_method_sk
DIM_MFA_METHOD ||--o{ FACT_SESSION : mfa_method_sk
DIM_LOCATION ||--o{ FACT_SESSION : location_sk

```

Reminder: Adjust column lists or dimension names in the snippet if you further tweak the schema above.

(Chart restored - no other content removed.)